



GUIDA PER LE PMI · FIRENZE

Sicurezza informatica: cosa vi verrà chiesto, e da chi

Otto pagine su quello che oggi vi viene domandato sulla sicurezza della vostra rete — dai clienti, dalle assicurazioni, dalla normativa — e su cosa serve avere pronto per rispondere.

DA DOVE ARRIVA LA DOMANDA

Quattro strade diverse, la stessa richiesta.

Non è più una questione tecnica: è una questione contrattuale. Chi ve lo chiede non vuole sapere se siete sicuri, vuole vedere che potete dimostrarlo.

NIS2 — D.lgs. 138/2024

Gli obblighi di gestione del rischio si sono estesi a più settori, e toccano anche i fornitori delle aziende già obbligate.

GDPR, articolo 32

Misure di sicurezza adeguate al rischio — e la capacità di documentarle, non solo di averle adottate.

Polizze cyber

Le compagnie chiedono evidenza di controlli periodici. Prima di emettere la polizza, e di nuovo dopo un sinistro.

Clienti e gare

Le aziende strutturate girano ai fornitori i questionari di sicurezza che sono tenute a compilare.

LA PIÙ CITATA, E LA PIÙ FRAINTESA

NIS2 in una pagina.

Cosa è cambiato

Il recepimento italiano della direttiva NIS2 (D.lgs. 138/2024) ha ampliato la platea dei soggetti tenuti a gestire il rischio informatico, includendo settori che prima ne erano fuori.

Perché riguarda anche chi non è nell'elenco

Le aziende obbligate devono tenere conto dei rischi che arrivano dalla loro catena di fornitura. Il modo pratico in cui lo fanno è chiedere garanzie ai fornitori — cioè a voi, anche se il vostro settore non compare da nessuna parte.

Cosa significa in concreto

Sapere che cosa avete collegato in rete, sapere quali problemi noti ci sono sopra, avere deciso in che ordine affrontarli, e poterlo mettere per iscritto.

Questa pagina è una sintesi divulgativa, non un parere legale: per la posizione della vostra azienda serve una valutazione specifica.

IL QUESTIONARIO DEL CLIENTE

Le domande che arrivano più spesso.

Cambiano nella forma, non nella sostanza. Se leggendole vi viene da rispondere "bisognerebbe chiedere a...", è già un'informazione utile.

Avete un inventario aggiornato dei dispositivi collegati alla rete?

Con quale frequenza vengono cercate le vulnerabilità note?

Come stabilite quali vulnerabilità chiudere per prime?

Chi ha accesso ai sistemi, e come viene revocato quando qualcuno esce?

Esiste un backup verificato, e quando è stato provato l'ultima volta?

Cosa succede nelle prime ore dopo un incidente, e chi lo decide?

[DA COMPILARE] Sostituire con le domande vere dei questionari che ricevete: sono più credibili di qualsiasi elenco generico, e mostrano che li avete già visti.

PRIMA DI POTER RISPONDERE

Le quattro cose da avere pronte.

Nessuna richiede un progetto: richiedono che qualcuno le abbia guardate almeno una volta e le abbia scritte.

1. L'inventario

Ogni dispositivo collegato: computer, server, stampanti, telecamere, gestionali, apparati di rete. Quasi sempre sono più di quelli che ci si aspetta.

2. Le vulnerabilità note

Quelle già pubbliche e già catalogate, cercate su ciascun dispositivo. Non serve un attacco per averle: bastano un firmware fermo e una password mai cambiata.

3. La gravità

Misurata con uno standard riconosciuto (CVSS), così che l'ordine di intervento non dipenda da chi lo propone.

4. Il piano

Cosa si chiude subito, cosa richiede una decisione, cosa può aspettare — e perché.

COME FUNZIONA UN CHECK-UP

Quattro passi, nessun fermo del lavoro.

1**Mappiamo tutti i dispositivi collegati**

Compresi quelli che nessuno ricordava più.

2**Cerchiamo le vulnerabilità già note**

Su ciascun dispositivo, con strumenti aggiornati.

3**Misuriamo quanto sono gravi**

Con lo standard CVSS, non a sensazione.

4**Vi diciamo cosa sistemare, in ordine**

E ve lo spieghiamo di persona, non via mail.

I dati restano dentro la vostra azienda. Il preventivo arriva prima di qualsiasi attività.

COSA VI RESTA IN MANO

Il documento, quattro parti.

Scritto per essere letto da voi, non solo da un tecnico — perché è il documento che finirà davanti a chi vi chiede garanzie.

Inventario

Ogni dispositivo collegato alla rete, elencato.

Vulnerabilità

Quelle note, trovate su ciascun dispositivo.

Gravità

Misurata con lo standard CVSS.

Piano di intervento

Cosa sistemare, in che ordine e perché.

[DA COMPILARE] Qui va una pagina vera del report, con nomi e indirizzi oscurati. È la prova che il documento esiste e che si capisce: vale più di tutta questa pagina.

COME SI COMINCIA

Mezz'ora, senza impegno.

Ci raccontate come è fatta la vostra rete, vi diciamo se un check-up ha senso e cosa comporterebbe. Se non ha senso, ve lo diciamo lo stesso.

Preventivo prima di iniziare

Nessun fermo del lavoro

I dati restano in azienda

Siamo a Firenze: persone con cui parlare

tecnolink.it — Check-up di sicurezza informatica